HelpDeskFlow

Full Screenwise Product Requirements Document (PRD)

A multi-tenant customer-support platform for ticketing, live chat, knowledge bases, SLAs, automation, reporting, billing and administration.

Document field	Specification
Product name	HelpDeskFlow (working name)
Document type / version	Product Requirements Document / v1.0
Status	Developer-ready baseline; validate commercial decisions before implementation
Primary users	Customers, agents, team leads, organization admins and platform admins
Proposed stack	Next.js, Node.js API, PostgreSQL, Redis/queue, private object storage
Product model	Multi-tenant SaaS; free trial and paid business plans

This document defines product behavior and implementation requirements. Pricing, limits, providers and legal obligations must be confirmed before launch.

1. Executive summary

HelpDeskFlow gives businesses one workspace to receive, organize, answer and measure customer-support requests. Customers submit tickets and find self-service answers; agents work from a unified inbox; managers configure teams, SLAs, workflows and reports; platform administrators manage tenants and subscriptions.

Product goals

- Centralize support requests from the customer portal, email and live chat.
- Reduce response time through assignment rules, saved replies, automation and clear ownership.
- Give customers transparent ticket status and self-service knowledge articles.
- Measure performance through SLA tracking, workload reports, CSAT and audit trails.
- Securely support multiple companies in one SaaS platform with strict tenant isolation.

Success metrics

- Time to first response and time to resolution.
- SLA attainment, overdue tickets, backlog age and reopen rate.
- Customer satisfaction (CSAT) and knowledge-base usefulness.
- Agent workload balance and ticket deflection estimates.
- Active organizations, trial conversion, churn and uptime.

Out of scope for initial release

- Full contact-center telephony and call recording.
- Native mobile apps; responsive web is required.
- A complete CRM, sales pipeline or marketing automation suite.
- Unreviewed AI-generated customer responses.

2. Personas, roles and tenancy

Role	Responsibilities	Permissions
Customer/requester	Create requests, attach files, reply, view status, rate resolution	Own tickets and public portal content
Agent	Handle tickets/chats, use macros, update status, add internal notes	Assigned/team tickets according to policy
Team lead	Triage, reassign, monitor SLA, review performance	Team queues and reports
Organization admin	Configure channels, teams, hours, KB, billing and integrations	Organization settings and data
Platform admin	Operate tenants, plans, abuse review and global settings	Cross-tenant access only when privileged and audited

Tenant isolation rules

- Every organization-owned record includes organization_id; verify membership on every request.
- Access in one organization must never grant access to another tenant’s tickets, files, reports or configuration.
- Platform-admin access is privileged, explicitly granted, logged and separate from normal organization workflows.
- UI hiding is not authorization; permissions must be enforced server-side.

3. Screenwise inventory: 36 primary screens

Screens may use tabs, drawers or responsive variants, but all listed capabilities must remain accessible.

A. Public website

1. Marketing home — Value proposition, product overview, benefits, demo CTA, proof points and footer.

2. Features — Ticketing, chat, automation, SLA, reports, knowledge base and integrations.

3. Pricing — Plan comparison, limits, billing cadence, trial details, FAQs and checkout CTA.

4. Customer support portal — Branding, search, sign-in, create-ticket CTA and recent public articles.

5. Knowledge base — Search, categories, articles, breadcrumbs, related content and feedback.

6. Company/contact/legal — Contact form, about, privacy, terms, cookie notice and status link.

B. Customer portal

7. Customer authentication — Sign-in, invitation acceptance, reset, email verification and optional SSO.

8. Customer dashboard — Open tickets, recent updates, create-ticket action and suggested articles.

9. Create ticket — Subject, description, category, priority, attachments, contact details and consent.

10. Ticket details — Timeline, public replies, attachments, status, reopen and close actions.

11. Live chat — Launcher, pre-chat form, queue state, transcript and offline ticket fallback.

12. Ticket history — Search and filter by status/date; paginate previous requests.

13. Profile/settings — Name, verified email, locale, notification preferences, sessions and sign-out.

C. Business support workspace

14. Organization onboarding — Create organization, company details, timezone, domain, invite team and choose plan.

15. Agent login — Secure sign-in, MFA/SSO if configured, session handling and recovery.

16. Agent dashboard — My tickets, team queue, SLA risk, unread chats and workload summary.

17. Unified inbox — Queues, saved views, filters, bulk actions, assignment and priority.

18. Ticket workspace — Customer context, conversation, internal notes, status, tags, assignment, SLA timer and audit events.

19. Chat inbox — Live conversations, queue state, transfer, notes, canned replies and transcript.

20. Customer directory — Search/filter customers, view activity and export if permitted.

21. Customer profile — Contact details, ticket history, tags, custom fields and consent history.

22. Team management — Teams, agent membership, role assignment, workload and availability.

23. Automation rules — Trigger/condition/action builder, test mode, enable/disable and run history.

24. SLA and business hours — Calendars, holidays, response/resolution targets, pause rules and escalation.

25. Knowledge base editor — Draft/review/publish, categories, versions, visibility and feedback.

26. Saved replies/macros — Reusable snippets, ticket actions, variables and permissions.

27. Reports/analytics — Volume, backlog, response/resolution, SLA, CSAT and agent/team performance.

28. Integrations/email channels — Mailbox, inbound/outbound email, webhooks, API keys and integration health.

29. Notifications, billing and settings — Preferences, plan, invoices, usage, branding, security, audit log and deletion requests.

D. Platform administration

30. Platform admin login — Dedicated privileged login, MFA, session controls and security events.

31. Platform overview — Tenant/user/subscription metrics, queue health and incidents.

32. Tenant management — Search tenants, status, suspend/reactivate, usage and audited support access.

33. User/subscription management — User status, roles, plans, entitlements and subscription history.

34. Billing operations — Invoices, failed payments, refunds where supported, dunning and reconciliation.

35. Abuse/moderation — Spam, malicious attachments, suspicious tenants, reports and policy actions.

36. Global settings/audit logs — Feature flags, defaults, retention, audit search and admin actions.

4. Core user journeys

Customer ticket journey

- Customer searches the knowledge base in the branded portal.
- If no answer is found, customer signs in or submits a request with required fields.

- System validates data, scans attachments, creates the ticket and sends confirmation.
- Routing and SLA rules select a queue/agent; updates are sent through configured channels.
- Agent replies publicly or adds an internal note, updates status and resolves the ticket.
- Customer confirms resolution or reopens within policy; CSAT is requested after closure.

Agent handling journey

- Agent opens unified inbox and selects a queue or saved view.
- Agent claims/receives assignment, checks context and SLA timer, then replies or transfers.
- Macros can apply permitted response text, tags, assignment and status changes.
- System logs material actions and recalculates SLA state.
- Resolved tickets leave active queues but remain searchable and reportable.

Live chat journey

- Visitor opens chat and completes the pre-chat form if enabled.
- System routes to an available team using configured rules.
- If nobody is available, show expected wait or offer ticket creation.
- Agent can transfer, use saved replies and convert chat to a ticket.
- Transcript and metadata follow the tenant retention policy.

Subscription journey

- Organization chooses a plan and enters billing details.
- Backend creates checkout session; client never determines payment status.
- Verified provider webhook updates subscription state idempotently.
- Failed payments trigger notifications and a configurable grace period.
- Authorized admins can view invoices and subscription history.

5. Functional requirements

Area	Requirements
Authentication	Verification, password reset, secure sessions, revocation, optional MFA/SSO and rate limits.
Ticketing	Create, assign, prioritize, tag, search, reply, internal note, status transitions, reopen and audit.
Conversation	Chronological messages, public/private visibility, attachments, safe rendering and notifications.
Routing	Rules by channel, category, priority, language, team, tier and hours; fallback queue required.
Live chat	Availability, queue, transfer, offline fallback, transcript, agent presence and spam controls.
Knowledge base	Draft/review/publish, version history, search, categories, visibility and feedback.
Automation	Triggers, conditions, actions, test mode, versioning, loop prevention and execution logs.
SLA	First-response/resolution targets, business calendar, pause/resume, warnings and escalation.
Analytics	Role-filtered metrics, date ranges, timezone handling, exports and definitions.
Billing	Plans, entitlements, invoices, payment status, usage, cancellation, grace period and verified webhooks.
Admin	Tenant lifecycle, support access with reason, abuse review, global config and audit trail.
Notifications	Email/in-app preferences, deduplication, retry and delivery status.

6. Ticket lifecycle and business rules

State	Meaning and rules
New	Created; routing begins immediately.
Open	Requires agent action; active SLA applies per policy.
Pending	Waiting for customer/external dependency; pause behavior must be visible and configurable.
On hold	Waiting on internal/external work; role permissions may restrict this state.
Resolved	Agent believes request is solved; customer may reopen within policy.
Closed	Final state; reopening may create a linked follow-up ticket.

- Ticket IDs are unique and human-readable within an organization; database IDs remain opaque.
- Internal notes must never appear in customer APIs, email notifications, exports or the public portal.
- Status changes follow a server-side transition map and are recorded in ticket history.
- User deletion must not silently remove records required for audit/legal retention; anonymize where appropriate.
- Email replies must be matched to the correct tenant/ticket with validated identifiers.
- Automation must be idempotent where possible and prevent recursive triggers and repeated notifications.

7. Data model

Use PostgreSQL with UUID primary keys, UTC timestamps, foreign keys, indexes and organization_id on tenant-owned data. Row-level security may be added as defense in depth, not as a replacement for API authorization.

Domain	Core tables
Identity/tenancy	users, organizations, organization_memberships, teams, team_memberships, roles, permissions, invitations, sessions
Tickets/conversations	tickets, ticket_fields, ticket_tags, tags, ticket_assignments, messages, message_attachments, ticket_events, ticket_relations
Chat	chat_sessions, chat_messages, agent_presence, chat_transfers
Automation/SLA	automation_rules, automation_runs, sla_policies, sla_events, business_hours, holidays, escalation_rules
Knowledge base	kb_categories, kb_articles, kb_article_versions, kb_feedback
Analytics/notifications	notification_preferences, notification_deliveries, metric_snapshots, report_exports
Integrations	integration_connections, email_channels, webhook_endpoints, webhook_deliveries, api_keys
Billing/operations	plans, plan_entitlements, subscriptions, invoices, payment_events, audit_logs, abuse_reports, feature_flags

Important entity fields

- organizations: id, name, slug, status, timezone, locale, plan_id, created_at.
- organization_memberships: organization_id, user_id, role_id, status, invited_by, joined_at.
- tickets: id, organization_id, public_id, requester_id, subject, description, status, priority, channel, team_id, assignee_id, due_at, created_at, updated_at, resolved_at.
- messages: id, organization_id, ticket_id, author_id, visibility, body, channel, created_at. Visibility must explicitly be public or internal.
- ticket_events: id, organization_id, ticket_id, actor_id, event_type, before_json, after_json, created_at.
- subscriptions: id, organization_id, provider_customer_id, provider_subscription_id, status, current_period_end, cancel_at_period_end.
- audit_logs: actor_id, organization_id nullable for global actions, action, target_type, target_id, reason and created_at.

8. REST API design

Use a versioned API such as /api/v1. Validate inputs server-side, use consistent error objects, cursor pagination for large lists, and service-layer authorization. Never expose payment secrets in the browser.

Method + route	Purpose	Access
POST /auth/login	Authenticate and issue session	Public, rate-limited
POST /auth/logout	Revoke current session	Authenticated
GET /me	Current user and memberships	Authenticated
GET /organizations/:orgId/tickets	Search/list tickets	Authorized org member
POST /organizations/:orgId/tickets	Create ticket	Customer or authorized agent
GET /organizations/:orgId/tickets/:ticketId	Read ticket and permitted messages	Authorized participant/agent
POST /organizations/:orgId/tickets/:ticketId/messages	Public reply or internal note	Permission depends on visibility
PATCH /organizations/:orgId/tickets/:ticketId	Update status/priority/tags/assignment	Agent/team lead
GET /organizations/:orgId/chats	List chat sessions	Authorized agent
POST /organizations/:orgId/chats/:chatId/transfer	Transfer chat	Authorized agent
GET /organizations/:orgId/kb/articles	Search visible articles	Public/member by visibility
POST /organizations/:orgId/automation-rules	Create rule	Organization admin
GET /organizations/:orgId/reports/overview	Read support metrics	Manager/admin
POST /billing/checkout-session	Create checkout session	Billing admin
POST /webhooks/payments/:provider	Process signed payment events	Provider signature verification
GET /admin/organizations	Search tenants	Platform admin only

API conventions

- Use predictable JSON envelopes; errors include code, message, request_id and field_errors when relevant.
- Use 400 invalid input, 401 unauthenticated, 403 forbidden, 404 inaccessible/nonexistent, 409 conflict, 429 rate limit and 5xx server failure.
- Use idempotency keys for retry-prone operations and payment workflows.
- Apply request-size limits, schema validation, pagination limits and output encoding.
- Use optimistic concurrency/version fields for conflict-prone edits.

9. Architecture and repository layout

Layer	Responsibility
Web frontend	Next.js + TypeScript, responsive layouts, accessible components, forms and loading/error states.
API backend	Node.js structured framework, service layer, authorization middleware and schema validation.
Database	PostgreSQL, migrations, foreign keys, indexes, tenant-aware queries and backups.
Cache/jobs	Redis/queue for email, notifications, automation, exports, SLA timers and webhook retries.
Realtime	WebSocket or managed realtime service for chat/inbox; polling fallback during degradation.
File storage	Private object storage, signed URLs, malware scanning and size/type validation.
Email	Transactional provider, inbound parsing and tenant-safe ticket threading.
Observability	Structured logs, metrics, traces, error reporting, health checks and alerts.
Payments	Provider checkout and signed webhooks; backend is source of truth for entitlements.

Suggested monorepo

- apps/web — Next.js UI and public/customer/agent/admin routes.
- apps/api — REST API and realtime gateway.
- apps/worker — background jobs and scheduled SLA/automation tasks.
- packages/ui — shared design system and accessible components.

- packages/contracts — shared types and API schemas.
- packages/config — lint, formatting and TypeScript configuration.
- infra — deployment definitions, environment templates and runbooks.

10. Security, privacy and compliance

- TLS in transit; encryption at rest for database, backups and object storage.
- Secure HTTP-only SameSite cookies, CSRF protection where applicable, and session rotation/revocation.
- Modern adaptive password hashing; no plaintext passwords or secrets in source control.
- MFA for platform admins and recommended for organization admins; SSO can be enterprise capability.
- Tenant-scoped authorization on every read/write; automated cross-tenant isolation tests.
- Rate limits for login, reset, ticket creation, chat and public endpoints.
- Private attachments, malware scanning, safe filenames and short-lived signed URLs.
- Sanitize rich text; protect webhooks against SSRF and unsafe redirects.
- Verify webhook signatures, timestamps and replay protection; persist event IDs for idempotency.
- Audit privilege changes, exports, billing changes, tenant suspension and privileged support access.
- Document retention, deletion/export, incident response, backup restoration and data-subject requests.

For an India/global launch, obtain qualified legal review for applicable privacy, consumer, tax, retention and cross-border transfer obligations. This PRD is engineering guidance, not legal advice.

11. Non-functional requirements

Dimension	Target / requirement
Availability	Initial target 99.5% monthly for core app, excluding published maintenance/third-party outages.
Performance	Typical API reads p95 under 400 ms under agreed load; reports/search may have separate budgets.
Frontend	Core flows usable on current major browsers and mobile widths; complete loading/empty/error states.
Accessibility	Target WCAG 2.2 AA for primary flows; keyboard access, labels, contrast and focus handling.
Scale	Indexed queries, background jobs, pagination and horizontal API scaling.
Reliability	Retry transient jobs with backoff; dead-letter failed jobs; idempotent webhooks/notifications.
Backup	Automated backups and restore drills; define RPO/RTO before production launch.
Observability	Request IDs, structured logs, queue depth, error rates, latency and SLA-job lag.
Localization	Store timestamps in UTC; render in user/org timezone; avoid hard-coded formats.
Maintainability	Migrations, API contracts, tests, lint/type checks, code review and runbooks.

12. Billing and monetization

Plan	Indicative entitlements
Free/trial	Limited agents, ticket volume or retention; core ticketing and portal.
Growth	More agents, automation, SLA policies, chat, standard reports and integrations.
Business	Advanced routing, custom fields, multiple teams, analytics, audit controls and higher limits.
Enterprise	SSO, advanced retention, custom support, governance and negotiated limits.

Pricing, quotas, trial length, taxes and payment provider must be confirmed before launch. Enforce entitlements on the backend and show plan limits before users reach them.

Payment failure handling

- Verify provider webhook signatures before processing events.
- Store provider event IDs and handle duplicate deliveries safely.

- Update subscription state only from trusted events or verified server-side reconciliation.
- Notify billing admins after failures; apply configurable retries and grace periods.
- Do not immediately delete customer data after cancellation/non-payment; follow documented read-only and retention policies.

13. Reporting and analytics definitions

Metric	Definition
First response time	Time from ticket creation to first qualifying public agent response; specify business-hours handling.
Resolution time	Time from creation to resolved state, with pause treatment documented.
SLA attainment	Eligible tickets meeting configured targets divided by eligible tickets.
Backlog	Tickets in active states at selected point in time; exclude closed by default.
Reopen rate	Resolved tickets reopened in the window divided by resolved tickets in the cohort.
CSAT	Positive responses divided by valid survey responses; show response count and window.
Deflection	Estimated proxy such as article views followed by no ticket creation; do not claim causality.

Reports must respect permissions, tenant scope, timezone and date boundaries. Exports should be private, expire after a short period and be logged.

14. QA and acceptance criteria

Release-blocking acceptance criteria

- Customer can submit a ticket, receive confirmation, reply and see only public messages.
- Agent can assign, prioritize, tag, reply, add an internal note and resolve a ticket.
- Cross-tenant API and file access tests fail closed for all tested resource types.
- SLA timers correctly account for business hours, holidays and pause rules.
- Automation can be tested, enabled, disabled and audited without uncontrolled loops.
- Chat falls back to ticket creation when no agent is available and preserves context.
- Knowledge-base drafts remain private until published; visibility is enforced by the API.
- Payment webhooks reject invalid signatures and process duplicate events idempotently.
- Billing status and entitlements are derived server-side, not from client-supplied values.
- Platform-admin actions are permission-gated and audited.
- Critical journeys pass desktop/mobile responsive and accessibility checks.
- Backups can be restored in a documented test and operational alerts are verified.

Test coverage

- Unit tests: ticket transitions, SLA calculations, permissions, entitlements and automation conditions.
- Integration tests: database transactions, email threading, webhook verification, retries and file access.
- End-to-end: signup, ticket creation, agent reply, customer follow-up, resolution, billing and tenant suspension.
- Security: IDOR, tenant leakage, XSS, CSRF, SSRF, rate limits, upload abuse and privilege escalation.
- Load: inbox search, ticket conversations, chat concurrency, notification queues and reports.

15. Delivery roadmap

Phase	Scope	Estimate
0. Discovery/design	Confirm pricing, roles, workflows, data model and integrations	1–2 weeks
1. Foundation	Auth, organizations, roles, tenant isolation, navigation and audit baseline	2–3 weeks
2. Ticketing MVP	Customer portal, ticket lifecycle, unified inbox, messages, email and attachments	3–4 weeks
3. Team operations	Teams, assignment, saved replies, business hours, SLA and settings	2–3 weeks
4. Knowledge/chat	KB search/publishing, live chat, offline fallback and chat-to-ticket	3–4 weeks
5. Automation/reporting	Rules, execution history, reports, exports and metric definitions	2–3 weeks
6. Billing/admin	Plans, checkout/webhooks, tenant operations, abuse review and global audit	2–3 weeks
7. Hardening/launch	Security, accessibility, load tests, restore drill, monitoring and docs	2–3 weeks

Indicative total: approximately 17–25 weeks for a small experienced team, depending on integrations, realtime architecture, scope and review cycles. This is a planning estimate, not a guarantee.

16. Risks and decisions to finalize

Decision / risk	Resolution needed
Product name/domain	Confirm final brand, domain, support email and tenant URL strategy.
Email channel	Choose inbound parsing/outbound provider; define threading and bounce handling.
Realtime chat	Choose managed service vs self-hosted WebSocket; define expected concurrency.
Payment provider	Select provider, currencies, tax invoices, refunds and dunning behavior.
Plan limits	Confirm agents, tickets, storage, chat, retention, automation and API quotas.
Data residency/retention	Document region, backup, retention, deletion and export process.
Future AI assistance	Define data handling, human review, prompt-injection defenses and disclosure.
Support access	Define break-glass access, approval, reason capture and audit review.

17. Definition of done

- Every screen has appropriate loading, empty, success, validation, forbidden and failure states.
- API authorization and tenant isolation are enforced server-side and tested.
- Database migrations, seed data, environment variables and deployment instructions are documented.
- Logs, metrics, alerts, backups, restore procedure and incident contacts are documented.
- Privacy policy, terms, retention and billing terms are reviewed before production use.
- Critical end-to-end, accessibility, security and performance tests pass.
- Analytics and operational dashboards do not expose cross-tenant data.
- Support/admin workflows cover suspension, payment failure, data export and privileged access.

End of document • HelpDeskFlow PRD v1.0